



BSOS

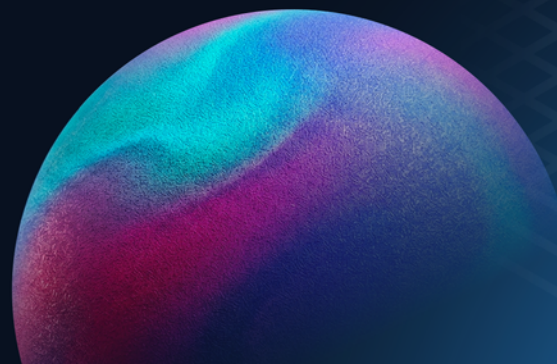
智能合約安全檢測報告

檢測工具

Slither

檢測日期

2026-08-14 ~ 2026-08-14



目錄

- 檢測範圍與方法
- 摘要
- 檢測結果

檢測範圍與方法

掃描範圍

本次檢測涵蓋以下 1 個 Solidity 原始檔（合計 84 行）。此清單即本報告的效力邊界——未列於此的檔案不在本次檢測範圍內。

檔案	行數
src/TimelockVault.sol	84

檔案內容雜湊（SHA-256），供比對交付程式碼是否與受檢版本一致：

src/TimelockVault.sol — 92b31524c7baf9e16ae14fe053dc4fd6bc3d26687eec07920493b059f839849d

檢測方法

本次檢測依以下步驟執行：

- 靜態分析掃描**：以 Slither 對「掃描範圍」所列全部原始檔執行完整 detector 掃描。
- 逐筆判讀與補充比對**：對掃描產出的每一筆發現判定其處置分類並記錄判斷依據，工具回報的嚴重度與本報告呈現的嚴重度若有落差則逐筆附上調整理由；同時對範圍內每一份合約，逐條比對內部維護的邏輯漏洞情境庫（權限檢查實作、未保護的狀態變更、旗標未落實、價格源可操縱、記帳與實際結果脫鉤、簽章雜湊綁定範圍、可組合模組的交互失效等），並依受檢系統所屬業務領域比對該領域公開已知的事故模式，補靜態規則無法涵蓋的業務邏輯層級問題。
- 產出與覆核**：彙整為本報告，並對共用同一判斷理由的發現群組進行抽查。

範圍限制

本報告由本檢測工具產出，解讀時請留意以下範圍限制：

- 偵測範圍**：靜態分析擅長偵測「程式寫法特徵層級」的問題（如重入模式、tx.origin 授權、弱亂數來源、未檢查的低階呼叫回傳值等）。
- 已知偵測邊界**：業務邏輯層級的問題——例如權限檢查的實作邏輯錯誤、應存在而未實作的保護、經濟模型層面的攻擊（搶跑、滑點）——靜態規則無法窮舉，本工具以情境庫逐合約比對補充涵蓋，但其涵蓋程度不等同於系統性審計。
- 文件性質**：本報告為交付前之**自我檢查證明**，證明工程團隊已執行掃描並對每一筆發現完成逐筆判讀；其不構成、亦不取代由獨立第三方執行之完整安全審計。

摘要

受檢對象：(測試夾具)

檢測期間：2026-08-14 ~ 2026-08-14

受檢版本：4eeef1e077b74137cc280cec07123b9a7a2a1ad0

本次共提出 6 項發現，依嚴重程度分布如下：

嚴重程度	筆數
Critical	0
High	0
Medium	0
Low	4
Informational	2
總計	6

全部發現逐筆列於「檢測結果」，依處置分類分組。

本受檢對象為迴歸測試夾具，不是要交付的產品合約：TimelockVault 是為驗證本工具判級邏輯而刻意設計的最小化定存型金庫，預期結果事先寫死（見 FIXTURE_NOTES.md）。此節的內容僅供版面驗證之用。

合約職責

合約	職責
TimelockVault.sol	接受 ETH 存入並鎖倉 7 天；到期後可提領，提領時收取手續費並累計於合約內

資產與托管

使用者存入的 ETH 全部停在 TimelockVault 自身；balances 記錄各地址可提領餘額，accruedFees 記錄尚未被提走的手續費。

特權角色權限表

角色	可呼叫	後果
owner（建構時設定，immutable）	sweepFees(address to)	把 accruedFees 全額轉往指定地址。不能動使用者的 balances。

檢測結果

本次共 6 項發現，本章逐筆列出其中 1 項。其餘 5 項為低嚴重度（Low／Informational）且經判定為可接受風險或誤報者，逐筆紀錄保留於工作底稿，可依需要調閱。

嚴重度	筆數
Critical	0
High	0
Medium	0
Low	1
Informational	0

處置分類	筆數
已知風險但可接受（B）	1

編號 [H-1] 為嚴重度代碼（C 危急／H 高／M 中／L 低／I 資訊）加該嚴重度內的序號，僅指派給經判定確實成立、需要處置的發現；經查證為誤報或已接受之風險沿用掃描編號。

已知風險但可接受（B）

[L-1] deposit() 每次加碼會重置整筆餘額的鎖倉期

位置：src/TimelockVault.sol:38-43

說明：unlockAt[msg.sender] 在每次 deposit() 時整筆覆寫為 block.timestamp + LOCK_PERIOD（L41），代表使用者加碼 1 wei 就會把既有全部餘額重新鎖 7 天。若前端或第三方合約代使用者存入，可能造成非預期的延長鎖倉。

影響：（待補 —— 具體危害與對應的業務損失）

PoC：（待補 —— 攻擊邏輯，或可重現的測試碼）

接受理由：與產品方確認過這是刻意設計（「任何異動重新起算定存期」），且已寫入使用者文件；技術上若要改為分批鎖倉需要 per-deposit 的紀錄結構，成本與收益不成比例。評估為可接受風險，於文件揭露。

建議修法：（待補 —— diff 或修改後的程式碼片段，與短期／長期建議）

附錄：發現處置分類

本報告對每一筆發現標示兩個獨立欄位：**嚴重度**（Critical／High／Medium／Low／Informational，由工程團隊依實際影響判定）與**處置**（下列 A／B／C／D）。掃描工具自身回報的 impact 若與本報告呈現的嚴重度不同，該筆會並列印出兩者與調整理由。

- **A | 已確認需修復**：確認為真實問題（多涉及資金流向或權限控制邏輯），必須修復。
- **B | 已知風險但可接受**：問題確實存在，但經工程團隊評估風險可控（例如僅管理者可呼叫、另有其他層級防護），附具體理由後接受並於報告揭露。
- **C | 誤報**：靜態分析限制造成的誤判，實際已有防護機制或該判斷邏輯不適用。

- **D | 待確認**：尚無法判定歸屬者一律列此類；判讀信心不足時寧列 D，不猜測分類。此類項目均附「要確認什麼／由誰確認／兩種答案各自的處置」。